

CERTIFICATION EXAM · 250-348

Cisco CyberOps Associate

300 Interview Questions & Answers

With Real-World Examples & Explanations

300

Questions

15

Categories

All Levels

Access Control

Cisco Security

Cloud Security

Compliance

Cryptography Basics

Cyber Threats

Data Security

Endpoint Security

Incident Response

Network Fundamentals

Network Security Devices

Security Fundamentals

Table of Contents

15 Domains · 300 Questions · Cisco CyberOps Associate 250-348

01 Access Control	12Q	09 Incident Response	30Q
02 Cisco Security	11Q	10 Network Fundamentals	45Q
03 Cloud Security	6Q	11 Network Security Devices	11Q
04 Compliance	11Q	12 Security Fundamentals	38Q
05 Cryptography Basics	24Q	13 Security Monitoring	33Q
06 Cyber Threats	51Q	14 Threat Intelligence	5Q
07 Data Security	7Q	15 Vulnerability Management	9Q
08 Endpoint Security	7Q		

Each question includes a detailed answer with a real-world example for practical understanding.

Access Control

Q1. What is RBAC?

Role-Based Access Control assigns permissions to roles, users are assigned roles. Simplifies permission management at scale.

Create roles: Admin (full access), User (limited access), Guest (read-only). Assign employees to appropriate roles.

Q2. What is multi-factor authentication?

Requires multiple authentication factors: something you know (password), have (token), are (biometric). Significantly reduces account compromise risk.

Login with password + SMS code + biometric. Even if password stolen, attacker needs phone and fingerprint to access account.

Q3. What is the difference between DAC, MAC, and RBAC?

DAC (Discretionary): owner controls access. MAC (Mandatory): system administrator controls based on security labels. RBAC (Role-Based): roles determine access.

DAC: File owner grants permission to user. MAC: System marks data SECRET, only SECRET-cleared users access. RBAC: Database Admin role has database access.

Q4. What is privileged access management?

Controlling and monitoring access to privileged accounts. Uses just-in-time access and session recording. Prevents privilege escalation.

Admin needs root access to fix issue. Request just-in-time access for 30 minutes. Session recorded. Access revoked after timeout.

Q5. What is single sign-on (SSO)?

Authentication mechanism allowing user to login once and access multiple systems. Simplifies user experience and administration.

Employee logs into SSO provider. Can access email, SharePoint, VPN, databases without logging in separately.

Q6. What is Kerberos?

Authentication protocol using symmetric encryption. Client, server, and KDC (Key Distribution Center). Used in Active Directory.

User logs into workstation using Kerberos. KDC issues ticket. User uses ticket to access file server without entering password again.

Q7. What is SAML?

Security Assertion Markup Language for federated authentication. Used for SSO in enterprise and cloud. XML-based assertions.

Employee logs into Okta (IdP). Okta creates SAML assertion. Employee accesses Salesforce (SP) using assertion. No password entry needed.

Q8. What is OAuth?

Authorization protocol allowing user to grant third-party access without sharing password. Commonly used for web and mobile apps.

Sign in with Facebook button. App redirects to Facebook. User authorizes, Facebook provides token. App uses token to access user data.

Q9. What is just-in-time (JIT) access?

Granting access only when needed, for limited time. Reduces exposure of privileged credentials. High security.

Admin requests access to production database for 30 minutes. JIT system grants access. Automatically revoked after 30 minutes.

Q10. What is password policy?

Rules governing password creation and management. Examples: length, complexity, expiration, reuse prevention.

Policy: minimum 12 characters, uppercase, lowercase, numbers, symbols. Expire every 90 days. Can't reuse last 5 passwords.

Q11. What is a privileged account?

Account with elevated permissions. Root, administrator, service accounts. Higher risk if compromised.

Administrator account for Active Directory. Service account for database. Both require strong protection and monitoring.

Q12. What is identity federation?

Linking user identities across multiple independent systems. Users manage single identity across systems.

Employee logs into corporate SSO. Same identity used for email, SharePoint, Salesforce. Single sign-on across all apps.

Cisco Security

Q13. What is Cisco ASA?

Adaptive Security Appliance provides firewall, VPN, and application security. Stateful firewall inspects traffic at multiple layers. Supports IDS/IPS modules.

ASA blocks traffic to port 23 (telnet), allows only port 443 (HTTPS). Can terminate VPN connections and filter encrypted traffic.

Q14. What is Cisco IOS?

Operating system for Cisco routers and switches. Security features include: access control lists (ACLs), authentication, encryption, and firewall capabilities.

Configure ACL on router interface to block traffic from specific subnets. Enable AAA for device authentication. Encrypt management traffic with SSH.

Q15. What is Cisco AnyConnect?

VPN client that provides secure remote access. Supports multiple platforms. Can enforce compliance checks before connecting (NAC integration).

Remote worker uses AnyConnect to securely connect to corporate network. Client verifies antivirus running, firewall enabled, patches current.

Q16. What is Cisco Umbrella?

Cloud-based security platform providing DNS filtering, malware protection, and threat intelligence. Blocks access to malicious domains at DNS level.

User tries to visit malware-distribution website. Cisco Umbrella blocks DNS resolution, prevents access without needing endpoint agent.

Q17. What is Cisco AMP?

Advanced Malware Protection for endpoint malware detection and protection. Uses behavioral analysis and signatures. Detects and blocks malware before, during, and after execution.

Unknown executable downloaded. AMP analyzes behavior in sandbox, detects malicious activity, blocks execution. User notified of threat.

Q18. What is Cisco Talos?

Cisco's threat intelligence organization. Provides threat data, research, and intelligence. Feeds threat information to Cisco security products.

Talos identifies new malware variant. Information shared with all Cisco products to block variant before it spreads widely.

Q19. What security certifications validate expertise?

For Cisco: CCNA (Cisco Certified Network Associate), CCNP (Cisco Certified Network Professional), Cisco CyberOps Associate. Also: CEH, CISSP, OSCP.

CCNA covers networking basics including security. CyberOps Associate covers security monitoring and incident response specifically.

Q20. What is Cisco ISE?

Identity Services Engine provides network access control and device profiling. Enforces policies based on device type and user identity.

ISE detects iPhone trying to access network. Applies policy: No access to file shares, only to guest network. Android gets different policy.

Q21. What does Cisco Catalyst do?

Next-generation switches with advanced security features. Provides threat detection, network segmentation, and application visibility.

Catalyst switch detects suspicious east-west traffic between servers. Applies microsegmentation policy, blocking unauthorized communication.

Q22. What is Cisco SecureX?

Cloud-native security platform integrating multiple Cisco security products. Provides unified visibility and automated response.

Alert from AMP about malware. SecureX correlates with other tools, updates firewall rules, isolates endpoint automatically.

Q23. What are Cisco best practices for security?

Update firmware regularly, use strong authentication, enable logging, implement defense in depth, conduct security assessments.

Update ASA firmware quarterly. Enable RADIUS authentication for admin access. Configure syslog to send logs centrally.

Cloud Security

Q24. What is the shared responsibility model?

Cloud provider secures infrastructure, customer secures data/access. Encryption, identity management, compliance, and data residency are shared.

AWS secures servers/data centers. Customer responsible for: encryption keys, IAM policies, network configuration, patch management.

Q25. What is cloud data protection?

Securing data in cloud: encryption at rest and in transit, access controls, monitoring, and DLP. Ensures confidentiality and integrity of cloud data.

S3 bucket encrypted with customer-managed KMS keys. Access controlled with IAM policies. CloudTrail logs all access. DLP prevents exfiltration.

Q26. What is identity and access management in cloud?

Managing user identities and access to cloud resources. Tools: IAM policies, role-based access, multi-factor authentication, directory services.

AWS IAM: Create role 'Developer' with specific S3 and Lambda permissions. Assign users to role. MFA required for sensitive operations.

Q27. What is cloud encryption?

Protecting data in cloud with encryption at rest and in transit. Using customer-managed or provider-managed keys.

S3 object encrypted with AES-256. API calls use HTTPS/TLS. Encryption key stored separately from data.

Q28. What is a cloud access security broker (CASB)?

Security tool providing visibility into cloud app usage. Enforces security policies. Detects shadow IT.

CASB monitors cloud apps: detect unauthorized app usage, enforce data protection policies, block access to risky apps.

Q29. What is cloud compliance?

Ensuring cloud services meet regulatory requirements. Cloud provider shares responsibility with customer.

Cloud provider achieves SOC 2, ISO 27001. Customer ensures encryption keys, access controls, data handling.

Compliance

Q30. What is GDPR?

General Data Protection Regulation (EU law) protects personal data. Requires consent, allows data access/deletion, mandates breach notification within 72 hours.

User requests their data. Company must provide all data collected. User requests deletion. Company must delete within 30 days or face fines.

Q31. What is HIPAA?

Health Insurance Portability and Accountability Act. Protects patient health information. Requires encryption, access controls, audit trails, and breach notification.

Healthcare provider must encrypt patient data at rest and in transit. Log all access to patient records. Notify patients if breach occurs.

Q32. What is PCI DSS?

Payment Card Industry Data Security Standard. Protects credit card data. Requires encryption, access controls, regular testing, and vulnerability scanning.

Company handling credit cards must encrypt card data, conduct penetration tests annually, disable default credentials, implement firewall.

Q33. What is SOC 2?

Service Organization Control audit for service providers. Reports on security, availability, processing integrity controls.

Cloud provider obtains SOC 2 Type II audit. Shows controls effective over 12-month period. Customers trust security.

Q34. What is ISO 27001?

International standard for information security management. Defines ISMS (Information Security Management System) requirements.

Organization achieves ISO 27001 certification. Shows implemented security management system according to international standards.

Q35. What is the difference between ISO 27001 and ISO 27002?

ISO 27001: Requirements for ISMS. ISO 27002: Code of practice with guidance on controls. 27001 is auditable, 27002 is guidance.

Use 27002 to select controls. Implement per 27002 guidance. Audit against 27001 requirements for certification.

Q36. What is NIST Cybersecurity Framework?

Voluntary framework for managing cybersecurity risk. Organized around five core functions: Identify, Protect, Detect, Respond, Recover.

Organization assesses current state against NIST framework. Identifies gaps. Creates roadmap to achieve target maturity level.

Q37. What is NIST 800-53?

NIST SP 800-53 defines security controls. Used by US federal agencies. Provides detailed control specifications.

AC-2 Account Management: Define authorization, create, enable, disable accounts. Manage privileged accounts.

Q38. What is CSF (Cybersecurity Framework)?

NIST Cybersecurity Framework provides guidance for managing cybersecurity risk. Five functions, 22 categories, 98 outcomes.

CSF functions: Identify, Protect, Detect, Respond, Recover. Implement controls across functions.

Q39. What is FISMA?

Federal Information Security Modernization Act. Requires US federal agencies implement NIST security standards.

Federal agency must implement controls per NIST 800-53. Assessed annually. Reported to OMB.

Q40. What is PCI compliance?

Compliance with Payment Card Industry Data Security Standard. Required if handling credit card data.

Merchant accepting credit cards must: encrypt card data, use strong authentication, conduct penetration tests, achieve annual certification.

Cryptography Basics

Q41. What is encryption and the two main types?

Encryption converts plaintext to ciphertext using a key. Symmetric encryption uses the same key for encryption/decryption. Asymmetric encryption uses a public/private key pair.

Symmetric: AES-256 encrypts and decrypts with same password. Asymmetric: RSA uses public key to encrypt, private key to decrypt.

Q42. What is a hash and what are its properties?

A one-way function that produces fixed-size output. Deterministic (same input = same output). Has avalanche effect (small change = completely different output). Cannot be reversed.

SHA-256('password123') = 'ef92b778baf771e89245d171bafb1d4371828c7af69b6ce0a3bd9a9b6a97'. MD5 is broken, use SHA-256 or SHA-3.

Q43. Explain salting in password hashing.

Adding random data to password before hashing. Prevents rainbow table attacks. Different salt per password even if passwords are identical.

Without salt: hash('password') = 'abc123'. With salt: hash('password'+ 'xyz789') = 'def456' (unique even with same password).

Q44. What is a digital certificate?

Binding of public key to identity. Contains public key, identity info, validity period, and issuer signature. Issued by Certificate Authorities (CAs).

Website certificate contains: public key, domain (www.example.com), validity dates (Jan 2024-2025), CA signature (Verisign, DigiCert).

Q45. What is PKI (Public Key Infrastructure)?

System for managing digital certificates and public-private key pairs. Enables secure communication, authentication, and digital signatures.

CA issues certificate to bank. When you visit bank.com, browser verifies certificate with CA, confirms bank's public key, establishes encrypted connection.

Q46. Explain SSL/TLS and how it works.

SSL/TLS provide encrypted communication. TLS is the modern standard. Uses symmetric encryption for data, asymmetric for key exchange, hashing for integrity.

HTTPS uses TLS. Client-server handshake exchanges keys, then all HTTP traffic is encrypted with AES, integrity verified with HMAC.

Q47. What is AES?

Advanced Encryption Standard. Symmetric encryption algorithm. Available in 128, 192, 256-bit key sizes. NIST approved, widely used.

AES-256 is secure for protecting government classified data. AES-128 is sufficient for most commercial applications.

Q48. What is RSA?

Asymmetric encryption algorithm using public-private key pairs. Used for key exchange, digital signatures. Security depends on difficulty of factoring large primes.

Web server has RSA public key in certificate. Client uses it to encrypt session key. Only server with private key can decrypt.

Q49. What is a Certificate Authority?

Organization that issues digital certificates. Verifies identity, signs certificates, maintains certificate revocation lists. Examples: VeriSign, DigiCert, Let's Encrypt.

CA verifies your own example.com domain. Issues certificate binding public key to domain. Browsers trust certificate because they trust CA.

Q50. What is symmetric encryption?

Uses same key for encryption and decryption. Fast, suitable for bulk data. Challenge: secure key distribution.

Shared password/key encrypts and decrypts data. Fast but need secure way to share key with recipient.

Q51. What is asymmetric encryption?

Uses public key (encryption) and private key (decryption). Enables secure communication without prior key sharing. Slower than symmetric.

Recipient publishes public key. Sender uses public key to encrypt. Only recipient with private key can decrypt.

Q52. What is hybrid encryption?

Combining symmetric and asymmetric encryption. Uses asymmetric to secure symmetric key exchange, then uses symmetric for bulk data.

Generate random AES key. Encrypt data with AES (fast). Encrypt AES key with recipient's public key (secure key exchange). Send both.

Q53. What is a key exchange protocol?

Mechanism for two parties to agree on encryption key over insecure channel. Examples: Diffie-Hellman, ECDH.

Diffie-Hellman: Two parties perform mathematical operations. Neither reveals secret but both compute same shared key.

Q54. What is HMAC?

Hash-based Message Authentication Code. Combines hash with secret key. Verifies both authenticity (sender) and integrity (data unmodified).

Send message + HMAC(message, secret_key). Receiver computes HMAC, compares with received HMAC. Match = authentic and unmodified.

Q55. What is a key management system?

System for creating, storing, rotating, and using cryptographic keys securely. Includes key generation, backup, recovery, and destruction.

HSM (Hardware Security Module) generates and stores encryption keys. Application uses HSM to encrypt/decrypt without accessing keys directly.

Q56. What is key rotation?

Periodically changing encryption keys. Limits damage from compromised key and ensures compliance with regulations.

Rotate database encryption key monthly. Old key decrypts old data, new key encrypts new data. If key compromised, only current data at risk.

Q57. What is a certificate revocation list (CRL)?

List of revoked digital certificates. Published by CA. Browsers check CRL to verify certificate validity.

Certificate issued to www.example.com. If private key compromised, certificate added to CRL. Browsers reject certificate even if not expired.

Q58. What is OCSP?

Online Certificate Status Protocol. Real-time checking of certificate revocation status. Alternative to CRL (more efficient).

Browser queries OCSP responder: 'Is certificate XYZ valid?' OCSP responds: 'Yes, valid' or 'No, revoked'. More efficient than downloading CRL.

Q59. What is perfect forward secrecy (PFS)?

Property ensuring compromised long-term key doesn't compromise past session keys. Each session uses unique key.

TLS with PFS: Session key generated uniquely per session. Even if server's private key compromised, past sessions still secure.

Q60. What is steganography?

Hiding secret message in visible content. Not encryption but concealment. Message visible but presence not obvious.

Hide secret message in image by modifying least significant bits. Image looks normal but contains hidden data.

Q61. What is the Diffie-Hellman key exchange?

Algorithm allowing two parties to establish shared key over unsecure channel. Neither reveals secret but derive same key.

Party A and B agree on prime p and generator g . A picks secret a , B picks secret b . Exchange $g^a \bmod p$ and $g^b \bmod p$. Compute shared key.

Q62. What is elliptic curve cryptography (ECC)?

Cryptography based on elliptic curves. Shorter key sizes than RSA but same security. Used in modern systems.

ECDSA (Elliptic Curve DSA): 256-bit ECC $\approx$ 2048-bit RSA in strength. Used in Bitcoin, TLS 1.3.

Q63. What is a one-time pad?

Theoretically unbreakable cipher using random key same length as plaintext. Each byte encrypted with random byte. Impractical.

Message: HELLO (5 letters). Key: XMCKL (5 random bytes). Ciphertext: EIVPV. Unbreakable but key distribution problem.

Q64. What is a cipher suite?

Set of cryptographic algorithms used together. Includes encryption, authentication, key exchange. Examples: AES-256-GCM.

TLS cipher suite: ECDHE for key exchange, AES-256-GCM for encryption, HMAC-SHA256 for integrity. Negotiated during handshake.

Cyber Threats

Q65. What is malware and what are the common types?

Malware is malicious software designed to harm systems. Types include: viruses (self-replicating), worms (spread over networks), trojans (disguised as legitimate), ransomware (encrypts data), and spyware (steals information).

WannaCry ransomware encrypted thousands of systems. Emotet trojan sent itself via email to build a botnet.

Q66. What is a virus and how does it differ from a worm?

A virus requires user action to spread (opening an infected file), while a worm spreads automatically over networks without user interaction. Both are self-replicating but spread through different mechanisms.

Email virus requires opening attachment to execute. Email worm uses address book to send itself to contacts automatically.

Q67. Explain phishing and spear phishing attacks.

Phishing is mass fraudulent email attempting to steal credentials. Spear phishing targets specific individuals with personalized, researched emails. Spear phishing is more sophisticated and has higher success rates.

Phishing: Mass email claiming PayPal is compromised. Spear phishing: Email to CEO from CFO requesting wire transfer with company letterhead.

Q68. What are password attacks and their common types?

Attempts to gain unauthorized access by cracking passwords. Types: brute force (try all combinations), dictionary attacks (common words), rainbow tables (precomputed hashes), keyloggers (capture keystrokes).

Brute force: try 192,838,473 combinations. Dictionary: try password, 123456, admin. Keylogger: capture when user types password.

Q69. What is social engineering?

Manipulation tactics to trick people into revealing confidential information. Techniques include: impersonation, pretexting, baiting, tailgating, and quid pro quo.

Attacker calls helpdesk pretending to be an employee, asks for password reset. Attacker leaves USB labeled Employee Salaries in parking lot (baiting).

Q70. Explain the concept of a botnet.

A network of compromised computers controlled remotely by an attacker. Used for DDoS attacks, spam distribution, cryptocurrency mining, and data theft.

Mirai botnet compromised 600,000 IoT devices, used for DDoS attack against Dyn DNS, causing major internet outages.

Q71. What is a DDoS attack and how does it differ from DoS?

DoS (Denial of Service) is from a single source, while DDoS (Distributed) is from multiple sources/botnets. Both overwhelm targets with traffic, making services unavailable.

DoS: Single attacker sends traffic flood. DDoS: Botnet of 1000 compromised computers sends traffic flood.

Q72. What are the common types of DDoS attacks?

Volumetric (UDP flood, DNS amplification), protocol (SYN flood, fragmented packets), and application layer attacks (HTTP flood, Slowloris). Each targets different layers and uses different techniques.

UDP flood: 10Gbps of UDP traffic. SYN flood: thousands of SYN packets. HTTP flood: send HTTP requests rapidly. Slowloris: send slow HTTP requests.

Q73. Explain SQL injection attacks.

Inserting malicious SQL code into input fields to manipulate database queries. Can extract, modify, or delete data, or bypass authentication controls.

Login form: SELECT * FROM users WHERE username='admin' AND password='anything' OR '1'='1'. The OR '1'='1' bypasses password check.

Q74. What is cross-site scripting (XSS)?

Injecting malicious JavaScript code into websites to steal user data or perform actions. Types: stored (persistent in database), reflected (non-persistent), and DOM-based.

Attacker posts comment with alert('hacked'). When users view comment, script executes, stealing cookies or session tokens.

Q75. What is a zero-day vulnerability?

Security vulnerability unknown to vendor or public. No patch available. Attackers can exploit it freely. Zero days are highly valued by attackers.

Microsoft Excel vulnerability unknown before April release. Attackers use exploit in campaigns before Microsoft releases patch.

Q76. What is ransomware?

Malware that encrypts victim's files, demanding payment for decryption. Types: crypto ransomware (encrypts data), locker ransomware (locks system access).

WannaCry encrypted files on thousands of computers worldwide, demanding Bitcoin payment for decryption keys.

Q77. What is a trojan horse?

Malware disguised as legitimate software. Executes malicious code once installed. User believes they are installing useful software.

User downloads 'Free Video Codec' but it's actually trojan that opens backdoor for attacker to access system.

Q78. What is a rootkit?

Malware that provides attacker with administrative (root) access. Difficult to detect because it operates at system level. Can hide other malware.

Rootkit installed on Linux system. Attacker has root access. Rootkit hides malicious processes from system tools.

Q79. What is a brute force attack?

Trial-and-error method to crack passwords or encryption. Tries all combinations until success. Slow but doesn't require knowledge.

Brute force SSH password. Try all 8-character passwords. ~16 million combinations. Takes weeks without rate limiting.

Q80. What is a dictionary attack?

Using predetermined word list to crack passwords. Faster than brute force but limited to common words.

Dictionary: password, 123456, admin, letmein, etc. Cracks most passwords within minutes. Becomes ineffective with proper hashing.

Q81. What is a rainbow table attack?

Using precomputed hash tables to crack passwords. Extremely fast but requires huge storage. Prevented by salting.

Rainbow table contains millions of hash-to-password mappings. Find hash in table, instantly learn password. Salt makes tables useless.

Q82. What is a timing attack?

Exploiting timing differences in cryptographic operations to extract information. Side-channel attack.

Password verification: system compares each character, fails immediately on mismatch. Timing indicates how many characters are correct.

Q83. What is a man-in-the-browser attack?

Malware installed in browser hijacking communications. Can modify transactions, steal credentials, inject content.

Banking malware in browser. User logs into bank, malware intercepts, changes transfer recipient to attacker account.

Q84. What is DNS spoofing?

Compromising DNS to redirect users to attacker's site. Attacker responds to DNS queries with false IP addresses.

User queries DNS for bank.com. Attacker's DNS returns attacker's IP instead of real bank. User connected to fake bank website.

Q85. What is ARP spoofing?

Sending fraudulent ARP messages to link attacker's MAC to legitimate IP address. Enables MITM attacks on local network.

Attacker sends ARP: My IP is 192.168.1.1 (default gateway), my MAC is attacker's MAC. Traffic intended for gateway goes to attacker instead.

Q86. What is IP spoofing?

Sending packets with false source IP address. Bypasses IP-based access controls. Enables reflection/amplification DDoS attacks.

Attacker sends DNS query with source IP of target. DNS response goes to target, overwhelming it. Attacker hidden behind false IP.

Q87. What is a memory leak?

Program fails to release allocated memory. Over time consumes all available memory, causing performance degradation or crash.

Web server allocates memory per request but doesn't release it. After 1000 requests, consumes 1GB. Eventually crashes.

Q88. What is a buffer overflow?

Writing more data to buffer than it can hold. Overwrites adjacent memory. Can inject executable code (code injection).

8-byte buffer receives 20 bytes. Extra 12 bytes overwrite return address on stack, redirecting execution to attacker's code.

Q89. What is a logic bomb?

Code deliberately inserted into program to execute malicious actions when conditions are met. Triggered by event or time.

Disgruntled employee inserts code: `if(date==termination_date) delete_all_databases()`. Executes after employee is fired.

Q90. What is a polymorphic virus?

Virus that changes its code with each infection to evade signature-based detection. Always looks different despite same functionality.

Virus encrypts core with different key each time. Antivirus signature won't match because code is different every iteration.

Q91. What is a metamorphic virus?

Virus that completely rewrites itself. More sophisticated than polymorphic. Can rewrite instructions in new ways.

Virus replaces ADD with equivalent MUL+DIV. To antivirus, looks completely different. Functionality remains same.

Q92. What is a drive-by download?

Automatically downloading malware when visiting compromised website. No user interaction required. Exploits browser vulnerabilities.

Visit news website with compromised ad. Exploit in ad downloads malware without user knowledge or consent.

Q93. What is watering hole attack?

Compromising website frequently visited by target group. Infects visitors with malware. Targets are likely to visit site.

Hackers compromise security forum visited by security professionals. Visitors unknowingly download malware. Professionals then spread to organizations.

Q94. What is a supply chain attack?

Compromising software/hardware supplier to inject malware into products. Affects all customers of compromised supplier.

Attacker compromises SolarWinds software development. Malware included in updates. Thousands of organizations receive infected updates.

Q95. What is typosquatting?

Registering domain names similar to legitimate sites (typos/variations). Tricks users into visiting attacker's site.

Attacker registers Goggle.com (instead of Google). User mistype gets directed to attacker's phishing site or malware download.

Q96. What is domain hijacking?

Unauthorized access to domain registrar account and changing DNS settings. Attacker controls domain without owning it.

Attacker gains access to domain registrar account. Changes nameservers to attacker's. All traffic for example.com now routes to attacker.

Q97. What is credential stuffing?

Using stolen credentials from one breach to access accounts on other sites. Many users reuse passwords across sites.

Hacker obtains 10 million username/password pairs from one breach. Attempts same credentials on Facebook, Gmail, etc. Many succeed.

Q98. What is privilege escalation?

Obtaining higher-level access than initially granted. Vertical escalation (user to admin), horizontal escalation (user to another user).

Web application vulnerability allows user to modify request to 'admin=true'. User gains admin privileges (vertical escalation).

Q99. What is a worm?

Self-replicating malware that spreads automatically over networks. No user action required. Can consume bandwidth and resources.

Worm exploits network vulnerability, automatically copies itself to other systems. Spreads exponentially without human intervention.

Q100. What is a Trojan?

Malware disguised as legitimate software. User believes installing useful program but actually installing malware. Opens backdoor for attacker.

User downloads 'Video Codec' but it's trojan that installs backdoor. Attacker gains remote access to computer.

Q101. What is ransomware?

Malware that encrypts files and demands payment for decryption. Can encrypt personal files or entire system. Destructive and damaging.

WannaCry ransomware encrypted files globally. Demanded Bitcoin payment. Users had no decryption key, data permanently lost.

Q102. What is spyware?

Malware that secretly monitors user activities. Steals passwords, browsing history, personal information. Often installed via bundled software.

Spyware logs keystrokes when user enters password. Transmits stolen credentials to attacker. User unaware of data theft.

Q103. What is adware?

Malware that displays advertisements. Often bundled with free software. Slower system performance. Can be vector for other malware.

Install free video player bundled with adware. Constant pop-up ads. System slows down. Ad clicks generate revenue.

Q104. What is a Trojan horse?

Malware hiding legitimate program appearance. Executes malicious payload when run. Different from worms (doesn't self-replicate).

Trojan email software with embedded backdoor. User runs software. Attacker gains remote access. Doesn't spread to other systems.

Q105. What is a rootkit?

Malware providing root/administrator access. Operates at OS level. Hides itself from detection. Very difficult to remove.

Rootkit installed on Linux. Attacker has root access. Hides malicious processes from 'ps' command. User unaware of compromise.

Q106. What is a botnet?

Network of compromised computers controlled remotely. Used for DDoS, spam, cryptocurrency mining, data theft. Infected computers called 'bots'.

Mirai botnet: 600,000 compromised IoT devices. Used for DDoS attacks. Victim's device infected, participates in attacks unknowingly.

Q107. What is macro malware?

Malicious macros in Microsoft Office documents. Executes when document opened. Bypasses file extension restrictions.

Word document with malicious macro that downloads ransomware. User opens document. Macro runs without warning. Ransomware installed.

Q108. What is fileless malware?

Malware existing only in memory, not written to disk. Evades file-based antivirus detection. Uses legitimate system tools.

PowerShell script downloaded into memory. Executes malicious code. No file on disk. Antivirus doesn't detect it.

Q109. What is a zero-day attack?

Exploiting unknown vulnerability with no patch available. Vendors have zero days to fix. Highly effective, difficult to defend against.

Vulnerability in Chrome unknown before April. Attackers exploit in campaigns for weeks before Google releases patch.

Q110. What is a drive-by download?

Automatically downloading malware when visiting compromised website. No user interaction. Exploits browser vulnerability.

Visit compromised website with malvertising. Browser vulnerability exploited. Malware downloaded and installed automatically.

Q111. What is a Trojan horse?

Malware pretending to be legitimate software. Contains hidden malicious payload. Users download voluntarily believing it's safe.

Fake antivirus software is trojan. User downloads to clean malware. Actually installs backdoor. Attacker gains access.

Q112. What is an advanced persistent threat (APT)?

Sophisticated, long-term attack by well-resourced attacker (nation-state, criminal group). Goals: espionage, data theft, sabotage.

APT29 (Cozy Bear): Russian intelligence agency. Targets government, healthcare. Long-term presence, stealth.

Q113. What is threat actor motivation?

Reason for attack. Financial (profit), political (espionage), ideological (hacktivism), personal (revenge).

Criminal: ransomware for profit. Nation-state: espionage. Hacker: challenge/glory. Disgruntled employee: revenge.

Q114. What is a logic bomb?

Malicious code triggered by specific condition or date. Executes harmful action when triggered. Hidden until activation.

Employee inserts code: if date=termination_date then delete_databases. Activates on expected termination date.

Q115. What is an information disclosure vulnerability?

Vulnerability exposing sensitive information. Can lead to privacy breaches, credential theft, or system compromise.

Web server exposes system information in error messages. Attacker learns technology stack, version numbers. Aids attack planning.

Data Security

Q116. What is data classification?

Categorizing data based on sensitivity: Public, Internal, Confidential, Secret. Different protection levels for each classification.

Public: marketing materials. Internal: employee directory. Confidential: financial data. Secret: customer credit cards (heavily restricted).

Q117. What is DLP?

Data Loss Prevention tools monitor and block unauthorized data transfer outside organization. Detect sensitive data and prevent transmission.

Employee tries to email customer list to personal email. DLP blocks email, alerts security team. Logs show attempted exfiltration.

Q118. What is data masking?

Replacing real data with fake but realistic data. Used for testing and development without exposing sensitive data.

Production has 10 million credit card numbers. Create test database with fake but realistic card numbers. Developers test without real data exposure.

Q119. What is tokenization?

Replacing sensitive data with random token. Real data stored separately. Can only retrieve real data with access to token mapping.

Store credit card number in secure vault. Store token '9b5e2c1a' in database. Token alone is useless without vault access.

Q120. What is data residency?

Legal requirement to store data in specific geographic location. Important for compliance with data protection laws.

GDPR requires personal data of EU residents stored in EU. Data cannot be transferred outside without additional safeguards.

Q121. What is data sovereignty?

Data subject to laws of country where stored. Affects data handling, access, and transfer.

Healthcare data stored in Australia subject to Australian privacy laws. Cannot be subject to foreign government access without compliance.

Q122. What is personally identifiable information (PII)?

Information identifying individual. Examples: name, SSN, email, phone, address. Requires special protection.

PII: John Smith, SSN 123-45-6789, john@example.com. Must be encrypted and access restricted.

Endpoint Security

Q123. What is endpoint protection?

Security for individual computers/devices. Tools: antivirus, EDR (Endpoint Detection & Response), DLP, firewall. Protection against malware, threats, data loss.

Endpoint agent detects malware, isolates device, collects forensics. EDR provides visibility into process execution, file modifications, network connections.

Q124. What is EDR?

Endpoint Detection and Response provides advanced endpoint security. Monitors process behavior, suspicious activities, and provides forensic capabilities.

EDR detects suspicious PowerShell execution (ransomware), terminates process, isolates device, collects logs for analysis.

Q125. What is an antivirus?

Software that detects and removes malware. Uses signature-based detection (known malware) and heuristics (suspicious behavior). Needs regular updates.

Antivirus detects malware file by signature match. Heuristic detection identifies suspicious behavior: modifying system files, accessing registry.

Q126. What is vulnerability scanning on endpoints?

Automated scanning of endpoints for missing patches, weak configurations, insecure software. Identifies risks at device level.

Endpoint vulnerability scan shows unpatched Java, disabled Windows Firewall, weak password policy. Generate remediation tickets.

Q127. What is application whitelisting?

Allowing only approved applications to run on endpoint. Blocks all other software including malware. Strict but secure.

Whitelist: Adobe Reader, Microsoft Office, Chrome. Block everything else. Even if malware downloaded, won't execute.

Q128. What is mobile device management (MDM)?

Managing mobile devices (phones, tablets) in enterprise. Controls, monitors, secures devices.

MDM solution enforces: password policy, app restrictions, device encryption, remote wipe capability.

Q129. What is a privileged access workstation (PAW)?

Hardened device used exclusively for administrative tasks. Enhanced security, limited functionality.

PAW used only for managing Active Directory. No email, internet, or personal use. Isolated network. Strong authentication.

Incident Response

Q130. What are the stages of incident response?

Preparation, detection & analysis, containment, eradication, recovery, and post-incident activities. Clear processes ensure effective response.

Detect ransomware, contain by isolating infected systems, eradicate by removing malware, recover from backups, review to prevent future incidents.

Q131. What is digital forensics?

Acquisition, analysis, and presentation of digital evidence. Preserves evidence integrity and chain of custody for legal proceedings.

Forensic team images hard drive bit-by-bit, analyzes deleted files, recovers logs, creates timeline of attacker activities.

Q132. Explain evidence preservation and chain of custody.

Improper handling can make evidence inadmissible in court. Chain of custody must be maintained. Use write-blockers and proper documentation.

Seized computer is photographed, sealed in evidence bag, stored securely. Each person handling signs chain of custody form.

Q133. What is containment in incident response?

Isolating compromised systems from network to prevent lateral movement. Critical for limiting breach scope. Can be short-term or long-term containment.

User's PC compromised. Firewall isolates device VLAN, blocking all traffic. Attacker cannot move to other systems.

Q134. What is root cause analysis?

Investigating incident to understand why it occurred. Identifies underlying causes, not just symptoms. Prevents similar incidents in future.

Incident: Employee phishing. Root cause analysis reveals lack of security awareness training. Solution: Implement mandatory security training.

Q135. What is a playbook?

Step-by-step procedures for responding to specific incident types. Ensures consistent, efficient response. Pre-defined actions, contacts, and decision trees.

Ransomware playbook: Isolate infected systems □ Notify leadership □ Contact law enforcement □ Restore from backups □ Post-mortem meeting.

Q136. What is recovery time objective (RTO)?

Maximum acceptable time to restore system/service after incident. Business requirement that drives recovery prioritization.

Email system RTO: 1 hour (critical). File sharing RTO: 4 hours (important). Development server RTO: 24 hours (lower priority).

Q137. What is recovery point objective (RPO)?

Maximum acceptable data loss measured in time. Determines backup frequency. Shorter RPO means more frequent backups.

Customer database RPO: 15 minutes (take backup every 15 minutes). Development database RPO: 1 day (daily backup sufficient).

Q138. What is incident severity?

Level indicating impact of incident. Critical (system down), High (significant impact), Medium (operational impact), Low (minor).

Critical: ransomware encrypting all servers. High: email phishing affects multiple users. Medium: unpatched vulnerability found. Low: policy violation.

Q139. What is incident classification?

Categorizing incident type for appropriate response. Examples: malware infection, data breach, DDoS, insider threat, system compromise.

Incident classified as 'Malware Infection'. Trigger malware response playbook: isolate system, preserve evidence, remove malware, restore.

Q140. What is a communication plan?

Pre-defined procedures for notifying stakeholders during incident. Who to contact, what information to share, escalation paths.

During data breach: Notify CEO □ Legal □ Customers (if required) □ Press. Each level has timing requirements.

Q141. What is a forensic image?

Bit-by-bit copy of storage device preserving all data including deleted files. Created with write-blocker to ensure evidence integrity.

Forensic team images suspect hard drive with Tableau write-blocker. Creates forensic image for analysis without modifying original.

Q142. What is evidence handling?

Proper procedures for handling evidence to maintain integrity for legal proceedings. Chain of custody, secure storage, controlled access.

Evidence bag sealed after collection. Labeled with date, collector, content. Signature required when opened. Maintains integrity for court.

Q143. What is system restoration?

Restoring systems to known good state after removing threats. Rebuild from scratch or restore from clean backup.

After ransomware removal, restore database from backup from 1 hour before encryption. Ensures clean state.

Q144. What is a backup and restore strategy?

Maintaining backups for disaster recovery. Includes full backups, incremental, backup verification, and restore testing.

Daily full backup, hourly incremental. Test restore monthly to ensure backups work. RPO 1 hour, RTO 4 hours.

Q145. What is the importance of documentation?

Recording all incident activities for audit trail, learning, and legal purposes. Includes timeline, actions, findings, recommendations.

Incident log: 9:00 AM alert received, 9:15 investigation started, 9:45 malware identified, 10:00 system isolated, 11:00 malware removed.

Q146. What is post-incident review?

Meeting after incident to discuss what happened, what worked, what didn't. Produces recommendations to prevent future incidents.

Ransomware incident review: Poor backup testing allowed 2-day recovery. Recommendation: Test restore monthly. Assign owner.

Q147. What is the importance of training?

Regular incident response training ensures team readiness. Includes tabletop exercises, simulations, and skill development.

Monthly tabletop exercise: simulate ransomware incident. Team practices detection, containment, communication, recovery procedures.

Q148. What is business continuity?

Plans and procedures to continue critical business functions during and after incidents. Minimizes downtime and service interruption.

If primary data center compromised, failover to secondary data center. Critical services resume within 4 hours.

Q149. What is a disaster recovery plan?

Detailed procedures for recovering from major incidents or disasters. Includes backup locations, recovery procedures, testing schedule.

Hot standby: secondary system always running, ready to take over immediately. Cold standby: secondary system powered down, takes hours to activate.

Q150. What is containment strategy?

Approach to stopping spread of incident. Short-term (immediate isolation) vs long-term (maintain evidence while fixing). Trade-off between evidence and containment.

Malware case: Short-term isolation stops spread. Long-term leaves infected system running to monitor attacker activities for investigation.

Q151. What is the importance of preparation?

Advance planning reduces response time and mistakes. Includes playbooks, contact lists, tools, and training.

Prepared: incident response runs smoothly, contained in hours. Unprepared: ad hoc response, mistakes, extended downtime.

Q152. What is breach notification?

Legal requirement to notify individuals of data breaches. Timing and content requirements vary by regulation (GDPR, HIPAA, state laws).

GDPR: 72-hour notification requirement. Email to affected users: what data breached, what being done, contact info for questions.

Q153. What is an incident commander?

Person directing incident response. Coordinates teams, makes decisions, manages communication. Ensures organized response.

During ransomware incident, commander directs isolation team, forensics team, communication team. Ensures coordinated response.

Q154. What is incident severity classification?

Categorizing incident by impact and urgency. Guides resource allocation and response procedures.

Critical: Executive system compromised, potential data breach. High: Multiple systems infected. Medium: Single system affected.

Q155. What is escalation procedure?

Clear procedures for escalating incident to higher authority when severity increases or situation worsens.

Detect phishing attempts (low). Escalate when user clicks and downloads malware (medium). Escalate to critical if malware spreads.

Q156. What is a war room?

Dedicated space where incident response team gathers for real-time coordination. Enables effective communication and decision-making.

During major incident, team gathers in war room. Real-time updates, immediate decisions, coordination.

Q157. What is victim notification?

Informing users or customers of incident affecting them. Legal requirement in many cases. Timing and content important.

Data breach notification: Send email to all customers. Explain data exposed. What being done. How to protect themselves.

Q158. What is incident reporting?

Documenting incident for regulatory compliance, lessons learned, and trending. Includes timeline, impact, actions.

Incident report: Date/time, description, systems affected, users impacted, timeline of events, resolution, recommendations.

Q159. What is threat hunting vs detection?

Detection: passively waiting for alerts. Hunting: actively searching for hidden threats using IOCs and threat intelligence.

Detection: IDS generates alert. Hunting: Security analyst searches logs for Cobalt Strike C&C; domains proactively.

Network Fundamentals

Q160. What is the OSI model and what are its seven layers?

The OSI (Open Systems Interconnection) model is a conceptual framework that standardizes communication functions. The seven layers are: Layer 1 (Physical), Layer 2 (Data Link), Layer 3 (Network), Layer 4 (Transport), Layer 5 (Session), Layer 6 (Presentation), and Layer 7 (Application). Each layer handles specific functions in network communication.

In a web request, Layer 7 handles HTTP, Layer 4 handles TCP, Layer 3 handles IP routing, and Layer 1 handles electrical signals over cables.

Q161. Explain the difference between TCP and UDP protocols.

TCP (Transmission Control Protocol) is connection-oriented, reliable, and ordered. It establishes a connection before data transfer and ensures all packets arrive in order. UDP (User Datagram Protocol) is connectionless, faster, and unreliable. It sends data without establishing a connection and doesn't guarantee delivery or order.

TCP is used for email and file transfers where reliability matters. UDP is used for video streaming and VoIP where speed is prioritized over reliability.

Q162. What is an IP address and how does IPv4 differ from IPv6?

An IP address uniquely identifies a device on a network. IPv4 uses 32-bit addresses (4 octets), providing ~4.3 billion unique addresses. IPv6 uses 128-bit addresses, providing ~340 undecillion unique addresses. IPv6 also has improved security, routing efficiency, and built-in IPsec support.

IPv4 example: 192.168.1.1 | IPv6 example: 2001:0db8:85a3:0000:0000:8a2e:0370:7334

Q163. What is a subnet mask and how is it used?

A subnet mask identifies which portion of an IP address is the network and which is the host. It uses binary 1s for the network portion and 0s for the host portion. Subnet masks enable network segmentation and efficient IP address allocation.

For 192.168.1.100 with mask 255.255.255.0: Network is 192.168.1.0/24 and host is .100. This subnet can have 254 usable host addresses.

Q164. Explain NAT (Network Address Translation) and its benefits.

NAT translates private IP addresses to public IP addresses and vice versa. It allows multiple devices on a private network to share a single public IP address. Benefits include enhanced privacy, security, and efficient use of IP address space.

A home router translates private addresses like 192.168.1.x to a single public IP when accessing the internet, hiding internal network structure from external hosts.

Q165. What is DHCP and how does it work?

DHCP (Dynamic Host Configuration Protocol) automatically assigns IP addresses and network configuration to devices. The DHCP process involves: Discover, Offer, Request, and Acknowledge (DORA). It eliminates manual IP configuration and manages IP address leasing.

When you connect a laptop to a wireless network, DHCP automatically assigns an IP from a pool (e.g., 192.168.1.100-200) with a lease period of 24 hours.

Q166. What is DNS and what does it do?

DNS (Domain Name System) translates domain names to IP addresses. It uses a hierarchical distributed database system with recursive and iterative queries. DNS enables human-readable addressing instead of memorizing IP addresses.

When you type www.google.com, DNS resolves it to an IP like 142.251.46.14, allowing your browser to connect to Google's servers.

Q167. Explain the purpose and function of a MAC address.

A MAC (Media Access Control) address is a 48-bit hardware address that uniquely identifies devices on a local network (Layer 2). It's formatted as 6 pairs of hexadecimal digits. MAC addresses are used for communication within the same network segment.

MAC address format: 00:1A:2B:3C:4D:5E. Used by ARP to resolve IP addresses to MAC addresses on the same local network.

Q168. What is ARP (Address Resolution Protocol) and why is it important?

ARP resolves IP addresses (Layer 3) to MAC addresses (Layer 2). When a device needs to communicate with another on the same local network, it sends an ARP broadcast to find the corresponding MAC address. ARP is essential for local network communication.

A device with IP 192.168.1.5 sends 'Who has 192.168.1.1?' broadcast. The device with that IP replies with its MAC address, enabling communication.

Q169. What is a gateway and what role does it play in networking?

A gateway is a network device that serves as an access point to another network. It translates protocols, addresses, and data formats between networks. The default gateway is the router that directs traffic destined for other networks.

Your home router (192.168.1.1) is the default gateway for all devices on your home network, directing internet-bound traffic to your ISP's network.

Q170. What is a VLAN?

Virtual Local Area Network is a logical grouping of devices independent of physical location. Segments networks for better performance, security, and management.

Create VLAN 10 for Finance, VLAN 20 for HR, VLAN 30 for IT. Devices in each VLAN require router to communicate (Layer 3 isolation).

Q171. What is STP?

Spanning Tree Protocol prevents loops in network topologies with redundant links. Blocks redundant paths creating a loop-free tree topology.

Network with three switches in triangle. STP blocks one link preventing broadcast storms and packet loops.

Q172. What is QoS?

Quality of Service prioritizes network traffic to ensure critical applications receive sufficient bandwidth. Manages congestion, reduces latency, prevents packet loss.

Configure QoS to prioritize VoIP (low latency), then video streaming, then bulk file transfers.

Q173. What is a DMZ?

Demilitarized Zone is a perimeter network segment that adds extra security. Servers exposed to internet while internal networks remain protected.

Firewall architecture: Internet □ Firewall □ DMZ (web servers) □ Firewall □ Internal Network.

Q174. What is a network topology?

Physical or logical arrangement of network devices. Physical topology describes actual layout, logical topology describes data flow. Common types: bus, star, ring, mesh, hybrid.

Star topology: All devices connect to central switch. Ring topology: Devices form circle. Mesh: Every device connects to every other.

Q175. What is bandwidth and latency?

Bandwidth is data transfer capacity (Mbps/Gbps). Latency is delay in data transmission (milliseconds). Both affect network performance.

High bandwidth, low latency: Fast file transfers with quick response. Low bandwidth, high latency: Slow downloads, noticeable delays.

Q176. What is packet fragmentation?

Breaking large packets into smaller fragments when crossing networks with smaller MTU (Maximum Transmission Unit). Reassembled at destination.

1500-byte packet needs to cross 1000-byte MTU network. Fragmented into two 500-byte packets plus headers. Reassembled at destination.

Q177. What is routing?

Process of determining optimal path for packets between networks. Routers use routing tables and protocols to forward packets toward destination.

Packet from 192.168.1.100 to 10.0.0.1. Router checks routing table, finds next hop, forwards packet accordingly.

Q178. What is a socket?

Endpoint of network connection combining IP address, port, and protocol (TCP/UDP). Used for communication between processes.

Server socket: 192.168.1.1:8080. Client socket: 192.168.1.100:54321. Communication established between these sockets.

Q179. What is port scanning?

Scanning a host to discover open ports and services. Can be SYN scan (stealthy), connect scan (noisy), or UDP scan. Used for reconnaissance.

Nmap scans target and finds port 22 (SSH), 80 (HTTP), 443 (HTTPS) open. Identifies running services.

Q180. What is traceroute?

Tool that traces path packets take to destination. Shows each hop (router) between source and destination with latency.

Traceroute example.com shows: Hop 1 (local gateway), Hop 2 (ISP router), Hop 3 (regional router), Hop 4 (example.com)

Q181. What is a tunnel?

Mechanism to encapsulate data from one protocol in another for transmission through unsupported network. Used for VPN, IPv4-over-IPv6, etc.

VPN tunnel: IPv6 packets encapsulated in IPv4 for transmission through IPv4-only network. Unwrapped at destination.

Q182. What is a network bridge?

Device connecting two network segments at Layer 2. Learns MAC addresses and forwards frames accordingly. Creates single broadcast domain.

Bridge connects Ethernet segment A to Ethernet segment B. Device on A can communicate with device on B as if on same network.

Q183. What is load balancing?

Distributing traffic across multiple servers to improve performance and reliability. Techniques: round-robin, least connections, weighted, IP hash.

Three web servers (A, B, C). Load balancer distributes requests: User1→A, User2→B, User3→C. Prevents overload on single server.

Q184. What is SDN (Software-Defined Networking)?

Network architecture separating control plane from data plane. Centralized control of network devices. Enables dynamic policies.

SDN controller applies security policies across network programmatically. Update policy once, apply to all switches automatically.

Q185. What is NFV (Network Function Virtualization)?

Running network functions (firewall, router, IDS) as virtual applications instead of hardware appliances. More flexible and scalable.

Deploy virtual firewall instances on demand using NFV. Scale elastically based on traffic. No need to buy hardware appliances.

Q186. What is zero trust networking?

Never trust, always verify model. Every access requires authentication. Microsegmentation limits lateral movement.

User must authenticate to access network segment. VPN provides only access to needed app. All traffic encrypted and logged.

Q187. What is the TCP three-way handshake?

SYN: Client sends SYN flag to server. SYN-ACK: Server responds with SYN and ACK flags. ACK: Client sends ACK flag. Connection established.

Client sends SYN with sequence number 100. Server responds SYN-ACK with seq 300, ack 101. Client sends ACK with seq 101, ack 301.

Q188. What is TCP connection termination?

FIN: One side sends FIN flag. ACK: Other side acknowledges. FIN: Responding side sends FIN. ACK: Original side acknowledges. Connection closed.

Four-way handshake: Client sends FIN, server ACKs, server sends FIN, client ACKs. Both sides cleanly close.

Q189. What is TCP window size?

Controls flow control. Tells sender how many bytes can be sent before waiting for acknowledgment. Prevents overwhelming receiver.

TCP window of 65535 bytes: sender can send up to 65535 bytes before receiving ACK. Prevents buffer overflow.

Q190. What is TCP retransmission?

Resending data when acknowledgment not received within timeout. Ensures reliable delivery. Timeout increases exponentially.

Send packet at time 0. No ACK by time 1 second. Retransmit. Timeout increases to 2 seconds for next potential retransmission.

Q191. What is the HTTP protocol?

HyperText Transfer Protocol. Application layer protocol for web. Request-response model. Stateless. Uses port 80.

Client sends GET request. Server responds with 200 OK and HTML content. Connection closes.

Q192. What is HTTPS?

HTTP over SSL/TLS encryption. Provides confidentiality and integrity. Uses port 443. Certificate verifies server identity.

Browser connects to https://example.com. Server provides certificate. Browser verifies certificate with CA. Encrypted connection established.

Q193. What are HTTP status codes?

1xx (informational), 2xx (success), 3xx (redirection), 4xx (client error), 5xx (server error). Indicate result of HTTP request.

200 OK: request successful. 404 Not Found: page doesn't exist. 500 Internal Server Error: server problem.

Q194. What is the purpose of cookies?

Store client-side data to maintain state across HTTP requests. Sent in all requests to server. Can be used for tracking.

Server sets cookie with session ID. Browser includes cookie in subsequent requests. Server identifies same user across requests.

Q195. What is SMTP?

Simple Mail Transfer Protocol. Sends email from client to server. Server to server transfer. Uses port 25/587.

Email client connects to SMTP server on port 587. Authenticates. Sends email. Server forwards to recipient's email server.

Q196. What is POP3 and IMAP?

POP3: downloads email and removes from server. IMAP: manages email on server. IMAP allows access from multiple devices.

POP3: Download emails to Outlook. Remove from server. Check email only on Outlook. IMAP: Check email on phone, laptop, web.

Q197. What is the purpose of firewalls?

Filters network traffic based on predefined rules. Blocks or allows traffic by protocol, port, IP address. First line of defense.

Firewall rule: Allow SSH (port 22) only from admin IP range. Block all other traffic to port 22.

Q198. What is stateful firewall inspection?

Tracks connection state. Distinguishes inbound/outbound. Allows response traffic without explicit rule. More sophisticated than stateless.

Outbound HTTP connection established. Firewall allows inbound response traffic automatically. No need for explicit return rule.

Q199. What is a demilitarized zone (DMZ) architecture?

Network segment separating internal network from internet. Public services in DMZ. Firewall between DMZ and internal. Defense in depth.

Web server in DMZ exposed to internet. Database server in internal network. Only web server can access database.

Q200. What is network address translation (NAT)?

Translates private IP addresses to public IP. Hides internal network structure. Enables multiple devices to share public IP.

Home network uses 192.168.1.0/24 (private). NAT translates to ISP's public IP when accessing internet. Hides internal structure.

Q201. What is port address translation (PAT)?

Mapping multiple private IPs to single public IP using different ports. Enables many internal users on single public IP.

192.168.1.10:1234 → 203.0.113.1:54321. Multiple internal devices use different ports on single public IP.

Q202. What is ICMP?

Internet Control Message Protocol used for diagnostics. Ping uses ICMP. Can be blocked by firewalls. Echo Request/Reply for connectivity testing.

ping google.com sends ICMP Echo Request. google.com responds with ICMP Echo Reply. Shows connectivity and latency.

Q203. What is a broadcast address?

Address that reaches all devices in subnet. Set all host bits to 1. Used for subnet-wide communication.

Subnet 192.168.1.0/24 has broadcast 192.168.1.255. Message to broadcast address reaches all devices in subnet.

Q204. What is a network prefix?

Leading bits of IP address identifying network. Remaining bits identify host. Written as /XX (e.g., /24 means 24 bits).

192.168.1.0/24: First 24 bits (192.168.1) are network, last 8 bits are host. Supports 254 hosts.

Network Security Devices

Q205. What is an IDS?

Intrusion Detection System monitors network for suspicious activity. Generates alerts when malicious traffic detected. Does not block traffic.

IDS detects SYN flood attack pattern, sends alert to analyst. Analyst reviews, confirms attack, manually blocks attacker IP on firewall.

Q206. What is an IPS?

Intrusion Prevention System actively blocks threats in-line. Automatically prevents malicious traffic. Can cause false positive impact if misconfigured.

IPS detects SQL injection attempt, automatically blocks connection, prevents exploit. Faster response than IDS but risk of false positives.

Q207. What is a WAF?

Web Application Firewall protects web applications from attacks. Understands HTTP/HTTPS. Blocks SQL injection, XSS, DDoS, and other web attacks.

WAF detects SQL injection in web form input, blocks request, logs incident. Protects web application without modifying code.

Q208. What is a Next-Generation Firewall?

Advanced firewall with application-level visibility and control. Inspects encrypted traffic, uses threat intelligence, supports IDS/IPS.

NGFW identifies YouTube traffic and blocks it based on policy. Inspects SSL/TLS traffic for malware. Blocks zero-day exploits using threat intel.

Q209. What is a VPN?

Virtual Private Network creates encrypted tunnel through public networks. Encrypts traffic and authenticates users. Two types: site-to-site and client-to-site.

Remote worker connects via VPN, secure tunnel created, traffic encrypted. From ISP's perspective, only VPN server is seen.

Q210. What is a proxy server?

Intermediary between clients and servers. Can provide caching, filtering, anonymity, access control. Forward proxies protect clients, reverse proxies protect servers.

Corporate forward proxy filters web traffic, caches content. Reverse proxy in front of web servers distributes load, hides server details.

Q211. What is a wireless intrusion prevention system?

Detects and prevents unauthorized wireless access. Identifies rogue access points, validates legitimate APs, blocks malicious traffic.

WIPS detects rogue AP broadcasting same SSID as corporate network. Automatically blocks it, alerts security team.

Q212. What is packet inspection?

Deep inspection of packets beyond header examination. Analyzes payload for threats. Can decrypt SSL/TLS for inspection.

DPI detects malware in HTTP payload. Rules block traffic based on content rather than just ports/IPs.

Q213. What is an NIDS vs HIDS?

NIDS (Network-based IDS) monitors network traffic. HIDS (Host-based IDS) monitors individual host. Different visibility and placement.

NIDS sees all network traffic. HIDS sees only traffic on single host. Combination provides comprehensive coverage.

Q214. What is a gateway?

Device connecting networks with different architectures. Translates between network types. Gateway for traffic between networks.

VPN gateway: connects remote users to internal network. Encrypts traffic, authenticates users.

Q215. What is a demilitarized zone (DMZ)?

Network segment separating internal network from internet. DMZ hosts public services. Firewall protects internal from DMZ.

DMZ contains web servers. Internal network contains databases. Firewall restricts communication between zones.

Security Fundamentals

Q216. What is the CIA triad?

The CIA triad consists of three core security principles: Confidentiality (only authorized access to data), Integrity (data accuracy and consistency), and Availability (authorized access when needed). It is the foundation of information security.

Encryption provides confidentiality, hashing ensures integrity, and redundancy/backups ensure availability.

Q217. Define authentication, authorization, and accounting (AAA).

Authentication verifies identity (who you are), authorization determines permissions (what you can do), and accounting logs activities (what you did). Together they form the AAA framework for access control.

Login with username/password (auth), access specific files (authz), system logs the action (acct).

Q218. What is the principle of least privilege?

Grant users/processes only the minimum access needed to perform their function. This reduces damage from compromised accounts and limits lateral movement by attackers.

A junior developer has read access to production logs but write access only to development systems.

Q219. Explain the difference between threats, vulnerabilities, and risks.

A threat is a potential danger, a vulnerability is a weakness, and risk is the probability that a threat exploits a vulnerability. Risk = Threat × Vulnerability × Impact.

Threat: hacker. Vulnerability: unpatched software. Risk: high if both exist and potential impact is significant.

Q220. What is vulnerability assessment?

The process of identifying, analyzing, and prioritizing vulnerabilities in systems. Uses automated tools and manual testing to find security weaknesses before attackers exploit them.

Nessus scan identifies 50 vulnerabilities. Prioritize by severity: critical (publicly exploitable), high (require specific knowledge), medium/low.

Q221. What is penetration testing?

Authorized simulation of cyberattacks to evaluate security. Penetration testers use hacking techniques to find exploitable vulnerabilities before real attackers do.

Pentester finds SQL injection in web app, exploits it to access database, and provides a remediation plan.

Q222. Explain the stages of a cyberattack (kill chain).

The seven stages are: Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command & Control, and Exfiltration. Identifying and stopping attacks at any stage prevents successful compromise.

Reconnaissance (scan network), weaponization (create malware), delivery (send phishing), exploitation (execute malware), C&C; (receive commands), exfiltration (steal data).

Q223. What is a security policy?

Formal set of rules and procedures governing security in organization. Defines acceptable use, incident response, access control, and enforcement.

Internet usage policy defines allowed websites, social media rules, personal device policies. Violations result in disciplinary action.

Q224. What is security hardening?

Process of reducing security vulnerabilities by applying patches, removing unnecessary services, and implementing security controls.

Remove unnecessary ports/protocols, update OS/applications, disable default accounts, enable audit logging on web server.

Q225. What is the attack surface?

Total of all possible entry points for unauthorized access. Reducing attack surface is key security goal.

Web app with 10 forms has larger attack surface than one with 2 forms. More forms = more possible injection points.

Q226. What is the difference between risk and threat?

Threat is potential harm, risk is probability of threat being realized. $Risk = Threat \times Vulnerability \times Impact$.

Threat: hacker. Risk: low (good security), high (poor security). Vulnerability: unpatched system. Impact: data breach.

Q227. What is a security baseline?

Minimum security standards defined for systems. All systems must meet baseline. Compliance checked regularly.

Baseline: Windows must have firewall enabled, virus protection active, Windows Update enabled, strong password policy.

Q228. What is configuration management?

Process of maintaining systems in desired security configuration. Tracks changes, enforces standards, audits compliance.

Use Ansible to deploy consistent firewall rules across all routers. Any deviation from baseline triggers alert.

Q229. What is secure coding?

Developing code with security in mind. Practices: input validation, output encoding, parameterized queries, error handling, avoiding hardcoded secrets.

Instead of: `SELECT * FROM users WHERE id='+userInput`, use parameterized query: `SELECT * FROM users WHERE id=?` with parameters.

Q230. What is OWASP and the Top 10?

Open Web Application Security Project. Top 10 lists most critical web application security risks. Updated regularly based on industry data.

OWASP Top 10: Injection, Broken Auth, XSS, XXE, Broken Access Control, etc.

Q231. What is security through obscurity?

Hiding implementation details for security. Not sufficient alone. Real security requires strong mechanisms regardless of implementation knowledge.

Hiding username/password fields from HTML is obscurity, not security. Use HTTPS encryption for real security.

Q232. What is data classification importance?

Classifying data based on sensitivity guides protection level. Prevents over-protecting public data or under-protecting sensitive data.

Public data: no restrictions. Confidential: encrypt in transit, restrict access. Secret: encrypt at rest, minimal access, audit all access.

Q233. What is a security control?

Safeguard to prevent, detect, or mitigate security risk. Preventive (stop), detective (find), corrective (fix), compensating (alternate).

Preventive: firewall blocks attacks. Detective: IDS alerts to attacks. Corrective: remove malware. Compensating: alternate authentication when primary fails.

Q234. What is security compliance?

Adhering to regulatory requirements and standards. Examples: GDPR, HIPAA, PCI-DSS, ISO 27001. Non-compliance results in penalties.

Healthcare organization must comply with HIPAA. Encrypt patient data, audit access, train staff, report breaches within 60 days.

Q235. What is a security assessment?

Evaluation of security posture to identify gaps and risks. Can be vulnerability assessment, penetration test, or audit.

Annual security assessment using NIST framework. Identifies 20 control gaps. Develop remediation plan with timelines.

Q236. What is security awareness training?

Educating users about security risks and best practices. Reduces human-based security incidents like phishing.

Annual training covers: phishing, password security, USB risks, social engineering. Followed by simulated phishing campaign to measure learning.

Q237. What is a security incident?

Violation of security policy, including malware, compromise, data breach, DDoS. Any event with potential security impact.

Incident: User compromised via phishing, malware installed, accessed customer database. Requires incident response.

Q238. What is the importance of regular backups?

Backups protect against data loss from failures, disasters, or attacks. Regular testing ensures backups work when needed.

Daily backups of critical databases. Test restore monthly. RPO 1 hour ensures minimal data loss.

Q239. What is BCP/DRP difference?

BCP (Business Continuity Plan) continues critical functions during incident. DRP (Disaster Recovery Plan) recovers from disaster.

BCP: Run on secondary system during incident. DRP: Recover from disaster, restore operations to normal.

Q240. What is risk management?

Process of identifying, analyzing, and mitigating risks. Includes risk assessment, prioritization, and implementation of controls.

Identify: unpatched servers. Analyze: high exploitability, high impact. Mitigate: implement patch management process.

Q241. What is threat modeling?

Identifying potential threats to system. Documents attack vectors and design vulnerabilities. Informs security architecture.

Threat model for web app: SQL injection, XSS, CSRF, authentication bypass. Design mitigations for each threat.

Q242. What is secure development lifecycle (SDLC)?

Incorporating security into software development process. Includes threat modeling, code review, security testing.

SDLC phases: Requirements (security), Design (threat model), Development (secure coding), Testing (security testing), Deployment.

Q243. What is secure code review?

Manual inspection of source code for security vulnerabilities. Identifies logic flaws, API misuse, insecure patterns.

Code review finds SQL injection vulnerability in login form. Developer fixes by using parameterized queries.

Q244. What is static application security testing (SAST)?

Analyzing source code for vulnerabilities without execution. Identifies coding issues like SQL injection, XSS.

SAST tool scans Java code, finds string concatenation in SQL query (SQL injection). Recommends parameterized queries.

Q245. What is dynamic application security testing (DAST)?

Testing running application for vulnerabilities. Tests actual behavior. Can find runtime issues.

DAST tool sends various inputs to web app. Finds stored XSS vulnerability. Recommends output encoding.

Q246. What is interactive application security testing (IAST)?

Hybrid approach combining SAST and DAST. Instruments application to monitor behavior during testing.

IAST tool runs app with test inputs. Monitors execution. Finds vulnerability and exact code line causing it.

Q247. What is API security?

Protecting APIs from attacks. Includes authentication, authorization, input validation, rate limiting.

API requires OAuth token for authentication. Rate limit: 1000 requests per minute per token. Validates input parameters.

Q248. What is container security?

Securing containerized applications. Includes image security, runtime security, orchestration security.

Scan Docker image for vulnerabilities. Run container with minimal privileges. Monitor container behavior at runtime.

Q249. What is infrastructure as code (IaC) security?

Securing infrastructure defined as code. Scanning code for misconfigurations. Prevents security issues in deployment.

Terraform code defines cloud infrastructure. Scan for S3 buckets with public access. Enforce encryption requirements.

Q250. What is defense in breadth?

Multiple security layers protecting different parts of system. If one layer fails, others continue protecting.

Network firewall, host firewall, antivirus, encryption, access control. Multiple layers protect data.

Q251. What is security posture?

Overall security effectiveness of organization. Measured by controls, policies, compliance, incident response capabilities.

Strong posture: updated systems, trained staff, incident response plan, regular assessments, compliance audits.

Q252. What is a security control assessment?

Evaluating control effectiveness. Determines if control working as intended. Identifies gaps and improvements.

Assess firewall control: verify rules exist, test blocking non-compliant traffic, review logs for enforcement.

Q253. What is a security control implementation?

Putting security control into place. Includes planning, configuration, testing, deployment, monitoring.

Implement MFA: select solution, configure servers, enroll users, test login process, monitor adoption.

Security Monitoring

Q254. What is SIEM and what does it do?

SIEM (Security Information and Event Management) collects and analyzes security logs from various sources. It correlates events, detects threats, and enables incident response.

Splunk/ArcSight collect logs from firewalls, IDS, servers. Correlate failed logins from multiple IPs indicating brute force attack.

Q255. What are log sources and why is logging important?

Log sources include firewalls, IDS, servers, databases, and applications. Logging creates audit trails for compliance, forensics, and threat detection.

Web server logs show requests, database logs show queries, firewall logs show traffic. Analyze together to detect data exfiltration.

Q256. What is log aggregation?

Collecting logs from multiple sources into a central location. Enables correlation, long-term storage, and analysis. Prevents log tampering on individual systems.

Use syslog to send logs from 100 servers to central SIEM. If attacker compromises one server's logs, central copy remains unmodified.

Q257. What are indicators of compromise (IOCs)?

Artifacts that suggest a system has been compromised. Include file hashes, IP addresses, domains, registry modifications, and behavioral signatures.

IOC: Hash of malware file, C&C; server IP, suspicious domain, unusual process execution. Search logs for these IOCs.

Q258. What is packet analysis?

Inspecting network packets to understand communication. Tools like Wireshark capture and analyze packets for security investigation and forensics.

Wireshark shows HTTP credentials in cleartext, suspicious DNS queries to malware C&C, or uncommon ports being used.

Q259. What is network flow data?

Summary of network communication (source, destination, ports, bytes transferred). More concise than full packet capture. Used for threat detection and forensics.

Flow shows server A to B on port 445 (SMB) with 500MB transferred. Unusual for these servers, indicates lateral movement/data exfiltration.

Q260. Explain baseline establishment for monitoring.

Defining normal behavior patterns for systems, users, and networks. Deviations from baseline indicate anomalies. Used for anomaly-based detection.

Baseline: Server uses 500MB memory, 20% CPU. Alert when memory spikes to 4GB or CPU to 95%, indicating malware activity.

Q261. What is a Security Operations Center (SOC)?

Centralized unit that monitors, detects, and responds to security incidents 24/7. Uses SIEM, analysts, and playbooks to detect and investigate threats.

SOC analyst sees alert from SIEM about suspicious login attempts. Investigates, confirms account compromise, initiates incident response.

Q262. What is an alert?

Notification triggered when monitoring system detects suspicious activity. Requires analyst investigation to determine if it's true positive or false positive.

SIEM alert: Multiple failed login attempts on admin account within 5 minutes. Analyst investigates to confirm if it's attack or mistyped password.

Q263. What is a false positive?

Alert triggered by normal behavior incorrectly flagged as malicious. Common when detection rules are too sensitive. Creates alert fatigue for analysts.

Alert: Unusual port usage detected. Investigation shows legitimate software update downloading files on non-standard port. This is false positive.

Q264. What is a true positive?

Alert that correctly identifies actual malicious activity. Confirms security system is working effectively and threat is real.

Alert: SQL injection attempt detected in web logs. Investigation confirms attacker was attempting database manipulation. This is true positive.

Q265. What is anomaly detection?

Identifying unusual patterns that deviate from baseline normal behavior. ML algorithms learn normal behavior and detect anomalies.

Baseline: employee accesses 10 files per day. Anomaly: suddenly accesses 1000 files. Indicates potential data exfiltration.

Q266. What is threat hunting?

Proactively searching for indicators of compromise or malicious activity. Doesn't wait for alerts. Uses historical data and IOCs.

Threat hunter searches logs for Cobalt Strike C&C; communications. Finds previously undetected communication in network traffic.

Q267. What is a correlation rule?

SIEM rule that combines multiple events to detect complex attacks. Single events aren't threatening but pattern indicates attack.

Rule: Alert if 5+ failed logins on same account from different IPs within 10 minutes. Indicates brute force attack.

Q268. What is a security dashboard?

Visual display of security metrics and KPIs in real-time. Helps identify trends and focus on critical issues.

Dashboard shows: incidents this month, open vulnerabilities, mean time to respond, top alert categories.

Q269. What is endpoint visibility?

Comprehensive monitoring of endpoint activities including processes, files, network connections, registry changes. Provided by EDR tools.

EDR shows all processes running, file changes, network connections for each endpoint. Analyst can see full activity timeline.

Q270. What is network visibility?

Monitoring network traffic to understand data flows and detect anomalies. Uses flow data, packet analysis, and protocol inspection.

Network monitoring shows unexpected large data transfer between database and personal email account. Indicates data exfiltration.

Q271. What is user behavior analytics (UBA)?

Monitoring user activities to detect anomalous behavior. Machine learning models establish baselines and detect deviations.

User typically works 9-5. UBA detects access at 3 AM accessing sensitive data at 10x normal volume. Indicates account compromise.

Q272. What is continuous monitoring?

Ongoing security monitoring rather than periodic assessments. Provides real-time visibility and faster threat detection.

Traditional: quarterly penetration test. Continuous: daily vulnerability scans, real-time IDS, log monitoring 24/7.

Q273. What is log retention?

How long security logs are stored. Balance between storage cost and compliance/forensics requirements.

HIPAA requires 6 years retention. Company stores logs locally for 3 months then archives for rest of retention period.

Q274. What is a correlation engine?

SIEM component that identifies relationships between events. Reduces noise by correlating unrelated events into single logical incident.

100 firewall alerts for same attacker IP. Correlation engine groups into single incident: Port scan attack from 10.0.0.5.

Q275. What is a honeypot?

Decoy system designed to attract attackers. Contains no real data but appears valuable. Monitors and logs all attacker activities.

Deploy honeypot server with fake credentials and vulnerable services. When attacker compromises it, security team analyzes attack techniques.

Q276. What is data retention for forensics?

Storing data long enough to analyze incidents after they occur. Enables post-mortem investigation and root cause analysis.

Keep firewall logs 90 days for forensics. When incident discovered, examine logs from previous month to find initial compromise point.

Q277. What is the role of a SOC?

Security Operations Center monitors security 24/7, detects threats, responds to incidents. Staffed by analysts and engineers.

SOC receives alert at 2 AM. Analyst investigates, confirms malware, initiates incident response, notifies relevant teams.

Q278. What is a security alert?

Notification from security monitoring system indicating potential threat. Requires human investigation to determine if real or false positive.

IDS alert: suspicious port scan detected. SOC analyst investigates, determines legitimate network admin scanning for devices.

Q279. What is event normalization?

Converting events from different sources into standardized format for SIEM analysis. Enables correlation across diverse systems.

Windows Event Log format different from Linux Syslog different from Firewall logs. Normalize to common format for unified analysis.

Q280. What is a security dashboard?

Visual representation of security metrics and KPIs. Provides real-time view of security posture.

Dashboard shows: incidents today, vulnerabilities by severity, patch compliance percentage, alert trends.

Q281. What is security analytics?

Analyzing security data to identify patterns, trends, and anomalies. Enables predictive threat detection.

Analytics shows spike in failed login attempts on Friday nights. Indicates potential brute force campaign.

Q282. What is a security metric?

Measurable indicator of security effectiveness. Examples: mean time to detect, patch compliance, incident response time.

Mean time to detect (MTTD): 4 hours. Mean time to respond (MTTR): 2 hours. Track improvement over time.

Q283. What is a KPI in security?

Key Performance Indicator measuring important security objectives. Examples: vulnerability remediation time, false positive rate.

KPI: Remediate critical vulnerabilities within 24 hours. Track compliance monthly. Report to management.

Q284. What is real-time monitoring?

Continuous monitoring and alerting on current events. Enables immediate threat detection and response.

IDS generates alert immediately when suspicious pattern detected. Analyst investigating within minutes.

Q285. What is forensic analysis?

Detailed investigation of security incident using logs, files, network traffic. Determines what happened.

Analyze firewall logs, system logs, network traffic to determine how attacker compromised system.

Q286. What is behavior-based detection?

Detecting threats based on unusual behavior rather than signatures. ML algorithms learn normal and detect deviations.

User normally logs in 9-5 weekdays. Behavior detection alerts when login at 2 AM weekend. Indicates account compromise.

Threat Intelligence

Q287. What is threat intelligence?

Information about threats and threat actors. Used to inform defensive strategies. Includes indicators of compromise (IOCs), TTPs, and attack trends.

Intelligence: APT29 uses Cobalt Strike for C&C; Organization may be targeted. Update firewall rules to block Cobalt Strike IPs and domains.

Q288. What is tactical threat intelligence?

Short-term intelligence about current threats and indicators. Used for immediate defense. Includes IOCs, malware samples, attack patterns.

Intelligence: APT group using malware variant XYZ. Update IDS signatures. Block known C&C; IPs. Identify similar activity in logs.

Q289. What is strategic threat intelligence?

Long-term intelligence about threat landscape and attacker intentions. Used for planning and decision-making.

Intelligence: APT29 targeting financial sector in 2024. Plan security improvements. Increase monitoring. Update incident response procedures.

Q290. What is operational threat intelligence?

Intermediate-term intelligence about specific threats. Informs short-term tactics and longer-term strategy.

Intelligence: APT group using spear phishing targeting our industry. Increase email filtering. Launch security awareness campaign.

Q291. What is IOC (Indicator of Compromise)?

Observable artifact indicating system compromise. Includes file hashes, IPs, domains, registry keys. Used in threat hunting.

IOC: Hash of malware, IP of C&C; server, suspicious domain. Search logs for these indicators to find compromised systems.

Vulnerability Management

Q292. What is CVSS?

Common Vulnerability Scoring System. Scores vulnerabilities 0.0-10.0. Used for prioritization: critical (9.0-10.0), high (7.0-8.9), medium, low.

Vulnerability X has CVSS 9.2 (critical) - fix immediately. Vulnerability Y has CVSS 4.3 (medium) - schedule for next patch cycle.

Q293. What is patch management?

Process of testing and deploying software updates to fix vulnerabilities. Critical for security. Regular patching reduces exposure to known exploits.

Microsoft releases patches first Tuesday of month. Organization tests patches in test environment then deploys to production systems.

Q294. What is a vulnerability scan?

Automated process of scanning systems for known vulnerabilities. Tools like Nessus, OpenVAS, Qualys. Generates list of findings by severity.

Run Nessus scan on web server. Tool identifies: unpatched Apache, weak SSL ciphers, unnecessary services. Create remediation plan.

Q295. What is zero-day vulnerability?

Vulnerability unknown to vendor or security community. No patch available. Attackers can exploit freely before disclosure.

Microsoft Excel vulnerability unknown before April release. Attackers exploit in campaigns before Microsoft releases patch in June.

Q296. What is vulnerability prioritization?

Ranking vulnerabilities by severity for remediation planning. Considers CVSS score, exploitability, system criticality.

Critical CVSS 9.2 on web server: fix immediately. Medium CVSS 6.0 on test system: schedule for next patch cycle.

Q297. What is the vulnerability lifecycle?

Phases: discovery, analysis, remediation, verification, closure. Continuous cycle of managing security weaknesses.

Scan discovers CVE-2024-1234. Analyze if applicable to our environment. Patch system. Re-scan to verify. Close ticket.

Q298. What is a vulnerability database?

Repository of known vulnerabilities. Examples: CVE (Common Vulnerabilities and Exposures), NVD (National Vulnerability Database).

CVE-2024-1234: Remote code execution in Apache. CVSS 9.8 critical. Search vulnerability database for details and patches.

Q299. What is configuration management?

Maintaining systems in consistent, secure configuration. Prevents drift and misconfigurations.

Use Ansible to deploy firewall configuration across all devices. Scan for deviations. Alert on unauthorized changes.

Q300. What is vulnerability tracking?

Maintaining inventory of vulnerabilities and remediation status. Tracks timeline, responsible parties, priority.

Vulnerability #1234: Critical SQL injection, assigned to dev team, due date April 15, status in progress. Track to closure.